Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.9 / COMPANION WORKBOOK

Bring in the fleet

50 Windows 11 endpoints, managed from first boot

Join the fifty-workstation fleet to a network that is ready for it: DHCP addressing, OU landing with STIG policy at first boot, Windows LAPS for every local administrator, certificate autoenrollment at scale, and a sampled proof with the whole rollout observed by the logging pipeline.

MATERIALS EDITION 1.2 / COURSE 1.9

Updated 8 October 2026 · sbd-workstation-fleet

NAME _____ / DATE _____

© 2026 Secure By Design Team LLC.

START HERE / YOUR LEARNING PATH

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Prepare the fleet rollout

02 Join the pilot and inspect first boot

03 Manage local administrators with Windows LAPS

04 Autoenroll the fleet's certificates

05 Admit only enrolled devices with 802.1X

06 Scale to fifty, enforce 802.1X, and prove by sample

07 Delta scan the fleet and hand off

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

Before you start

Fifty endpoints join a network that is finally ready for them: addressed by DHCP, landed by OU redirect, hardened by policy at first boot, certified by autoenrollment, and watched by the pipeline from their first sign-in. The sample names run SBD-PC01 through SBD-PC50; match them to your own plan.

Prerequisites

- ☐ Complete courses 1.5–1.8: routed network, working PKI services, DHCP with its relay, the tiered admin plane, and the logging pipeline.
- ☐ Prepare a patched Windows 11 reference image (or template) for the fifty endpoints, obtained through the approved offline media process.
- ☐ Confirm the Workstations OU, the container redirects from course 1.3, and the Defense Information Systems Agency (DISA) Windows 11 Security Technical Implementation Guide (STIG) Group Policy objects (GPOs) from the course 1.3 package are ready to link.
- ☐ Confirm the VLAN 80 access switch supports 802.1X port authentication, including a monitor (audit) mode that logs each result without blocking traffic. No new server is needed: the Network Policy Server (NPS) role goes on SBD-DHCP01.

What this course builds

- Roll fifty endpoints in waves that land hardened, addressed, and registered untouched.
- Manage every local administrator with Windows LAPS under the tier model.
- Prove the fleet with a defined sample, a failure rule, and pipeline-observed joins.

Systems in scope

RECORD	YOUR OBSERVATION
50 Windows 11 PCs — name, address, OS build	
SBD-DHCP01 — name, address, OS build	
SBD-SUBCA01 — name, address, OS build	

© 2026 Secure By Design Team LLC.

LESSON 01 / ABOUT 30 MIN

Prepare the fleet rollout

> **WHY THIS MATTERS** Fifty of anything needs a factory, not fifty craft projects. Settle the image, the names, the join account, and the policy links so every endpoint is born identical — then prove it on paper before proving it on metal.

In this lesson you will

- Finalize the reference image and naming plan for fifty endpoints.
- Create a least-privilege join account scoped to the Workstations OU.
- Link the Windows 11 STIG policies and the workstation firewall policy to the Workstations OU before any join.

Follow the build

1. Finalize the Windows 11 reference image: current patches via the approved media process, no preinstalled extras, and a generalized state so each clone takes its own identity. Record the image version and hash — it is the fleet's common ancestor and belongs in evidence.
2. Write the naming and rollout plan: SBD-PC01–SBD-PC50, addressed by the course 1.7 DHCP scope, joined in waves (pilot of three, then batches) rather than all fifty at once.
3. Create a dedicated domain-join account delegated only the create-computer-objects right on the Workstations OU — no broader privilege rides along with fifty join operations. The course 1.3 redirect already guarantees machines land in that OU.
4. Link the DISA Windows 11 STIG policies from the course 1.3 package to the Workstations OU now, so the very first pilot boots into the hardened state — and note that Windows 11's own secure defaults will already satisfy some checks, just as Server 2025 did.
5. Create the workstation firewall GPO (SBD Workstation Firewall in this sample) on the Workstations OU: Windows Defender Firewall on for every profile with inbound traffic blocked by default, and inbound rules that allow SMB (TCP 445), Remote Desktop (TCP 3389), and remote management (TCP 5985–5986) only from SBD-ADMIN-PC01 at 10.0.60.30 — course 1.10 adds SBD-NESSUS01 for credentialed scans. No rule allows SMB or Remote Desktop between workstations: traffic inside VLAN 80 never reaches the router, so this policy, not the course 1.5 router rules, enforces the register's peer denies.

Check your result

```
Get-FileHash -Algorithm SHA256 C:\Staging\Win11-Reference.vhdx
Get-ADOrganizationalUnit -Identity 'OU=Workstations,OU=SBD,DC=sbd,DC=test'
Get-GPInheritance -Target 'OU=Workstations,OU=SBD,DC=sbd,DC=test'
Get-GPOReport -Name 'SBD Workstation Firewall' -ReportType Html -Path C:\Evidence\
workstation-fleet\workstation-firewall.html
```

> **WHAT SUCCESS LOOKS LIKE** The image is hashed and recorded, the join account holds only the delegated right on the Workstations OU, and the STIG and firewall GPO links show on that OU before any machine exists in it.

Your record

Evidence to keep: Keep the image record with its hash, the naming and wave plan, the delegation report for the join account, the OU's GPO inheritance output, and the firewall GPO report.

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why does the join account get only create-computer rights on one OU?

> **REMEMBER** One hashed image, one naming plan, waves instead of a big bang. The join credential can create computer objects and nothing else. The Workstations OU is armed with policy before it holds a machine. Peer SMB and Remote Desktop are blocked by each PC's own firewall, set by policy before the first join.

DISA · STIG Group Policy Objects package

Microsoft · Configure Windows Firewall rules with Group Policy

NIST · SP 800-53 Rev. 5 security controls

LESSON 02 / ABOUT 30 MIN

Join the pilot and inspect first boot

WHY THIS MATTERS Three machines go first, and everything the path has built shows up at once: a DHCP lease through the relay, an OU landing, STIG policy, a DNS record — and the join itself appearing on the analyst's screen.

In this lesson you will

- Join a three-machine pilot with the scoped account.
- Verify lease, OU placement, policy, and DNS registration per machine.
- Confirm the joins appear in the logging pipeline.

Follow the build

1. Deploy SBD-PC01 through SBD-PC03 from the image into VLAN 80, let each take its DHCP lease, and join sbd.test with the delegated account — nothing about the join should require a privileged credential.
2. Per machine, verify the inheritance chain: the computer object sits in the Workstations OU (the redirect working), gpresult shows the STIG policies applied, and the secure dynamic DNS record exists on both DCs.
3. Confirm the deny side holds: a pilot machine cannot reach another pilot machine's SMB or RDP — the lesson 1 firewall policy refuses it on the destination PC, because traffic inside VLAN 80 never reaches the router — and cannot open anything toward VLAN 60, which the course 1.5 router rules deny at the boundary.
4. Find the three joins in the logging pipeline: the domain controller events for the computer-account creations should already be on the collector and searchable in analysis — the first machines this network has watched arrive.

Check your result

```
Get-ADComputer -SearchBase 'OU=Workstations,OU=SBD,DC=sbd,DC=test' -Filter * | Select-
Object Name, DNSHostName
gpresult /r /scope:computer
Resolve-DnsName SBD-PC01.sbd.test
Test-NetConnection SBD-PC02.sbd.test -Port 445   # expected: TcpTestSucceeded False
```

WHAT SUCCESS LOOKS LIKE All three pilots sit in the Workstations OU with STIG policy applied and DNS registered, peer SMB/RDP fails as designed, and the join events are visible in analysis.

Your record

Evidence to keep: Keep each pilot's placement, gpresult, and DNS proof; the peer-deny output; and the analysis search showing the three computer-account creations.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	

RECORD	YOUR OBSERVATION
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

How does a brand-new machine end up hardened without anyone touching it?

> **REMEMBER** Three pilots: leased, landed, hardened, registered — untouched by hand. Peer traffic fails by design; the denies are the fleet's first evidence. The pipeline watched the fleet being born.

Microsoft · Configure certificate autoenrollment

DISA · STIG Group Policy Objects package

Microsoft · Use Windows Event Forwarding to help with intrusion detection

Microsoft · Configure Windows Firewall rules with Group Policy

LESSON 03 / ABOUT 25 MIN

Manage local administrators with Windows LAPS

> **WHY THIS MATTERS** Fifty identical machines must not share one local administrator password. Windows Local Administrator Password Solution (Windows LAPS) gives each endpoint its own rotating secret, stored in the directory, readable by the people the tier model says may have it.

In this lesson you will

- Prepare the directory schema and permissions for Windows LAPS.
- Apply the LAPS policy to the Workstations OU.
- Retrieve and rotate a managed password under the tier rules.

Follow the build

1. Extend the directory schema for Windows LAPS (Update-LapsADSchema) and grant the Workstations OU's computers the right to update their own password attributes — a one-time Tier 0 action, performed from the jump host and recorded like any schema change.
2. Grant read access on the managed passwords to the Tier 2 admin group only — exactly the people SBD-ADMIN-PC01 exists for — and nobody else; the tier model decides who may know an endpoint's local secret.
3. Create the LAPS GPO on the Workstations OU: managed built-in administrator, the password complexity and age the plan sets, and post-authentication reset so a used password does not live on.
4. On a pilot, confirm the policy applied, retrieve the password from the admin seat, use it once, and watch rotation — one cycle, fully observed, is the proof the other forty-nine inherit.

Check your result

```
Get-LapsADPassword -Identity SBD-PC01 -AsPlainText   # from SBD-ADMIN-PC01, Tier 2 admin
Get-ADComputer SBD-PC01 -Properties msLAPS-PasswordExpirationTime | Select-Object Name,
msLAPS-PasswordExpirationTime
gpresult /r /scope:computer
```

> **WHAT SUCCESS LOOKS LIKE** The schema holds the LAPS attributes, only the Tier 2 group can read passwords, the policy shows on the pilots, and one retrieve-use-rotate cycle is recorded.

Your record

Evidence to keep: Keep the schema-change record, the permission delegation, the LAPS policy report, and the observed rotation cycle.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

What problem does LAPS remove from a fifty-machine fleet?

> **REMEMBER** Every endpoint owns its own rotating local secret. Reading rights follow the tier model, from the Tier 2 seat. One full cycle is observed and on record.

Microsoft · Windows LAPS overview

Microsoft · What's new in Windows Server 2025

LESSON 04 / ABOUT 25 MIN

Autoenroll the fleet's certificates

WHY THIS MATTERS Course 1.6 proved autoenrollment on a pilot group; this lesson turns it loose. Widen the template permission to the fleet, let policy do the enrolling, and verify a machine certificate chains and checks revocation across the boundary.

In this lesson you will

- Widen the computer template's autoenrollment to the fleet.
- Confirm hands-free enrollment at Group Policy refresh.
- Verify chain and live revocation from an endpoint.

Follow the build

1. Through the course 1.6 change process, update the SBD Computer Authentication template's autoenrollment permission from the pilot group to the Workstations OU's computers — the change record names the widening and its approver.
2. Confirm the autoenrollment policy already applies through the Workstations OU, refresh policy on the pilots, and watch certificates arrive with no human in the loop.
3. On an enrolled endpoint, run the full verification: the chain must reach the approved root, and the AIA and CDP fetches must answer live from pki.sbd.test through the course 1.5 register row.
4. Record the issuing CA's view: the issued-certificate log now shows the fleet enrolling — volume the CA was designed for, finally arriving, and itself a record worth sampling into evidence.

Check your result

```
gpupdate /force
Get-ChildItem Cert:\LocalMachine\My | Select-Object Subject, NotAfter
certutil -verify -urlfetch C:\Evidence\fleet\SBD-PC01.cer
```

WHAT SUCCESS LOOKS LIKE Pilot endpoints enroll hands-free at policy refresh, verification passes with live publication retrieval, and the CA's issued log reflects the fleet with the widened template version.

Your record

Evidence to keep: Keep the template change record, an endpoint's certificate details, the urlfetch output, and a sample of the CA's issued log.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

What governs widening the template from pilot to fleet?

REMEMBER The widening went through the change process, not around it. Enrollment is hands-free and verified live across the boundary. The CA's issued log joins the evidence.

Microsoft · Configure certificate autoenrollment

NIST · SP 800-53 Rev. 5 security controls

LESSON 05 / ABOUT 30 MIN

Admit only enrolled devices with 802.1X

WHY THIS MATTERS Until now, anything plugged into a VLAN 80 port got an address. With 802.1X, the switch asks each machine to prove who it is with the certificate it enrolled. This lesson turns that check on in monitor mode — every result is logged, nothing is blocked yet — because 47 PCs have no certificate until they join the domain; lesson 6 enforces it once the whole fleet has enrolled. No new server: the NPS role joins DHCP on SBD-DHCP01.

In this lesson you will

- Add the Network Policy Server (NPS) role to SBD-DHCP01 for port authentication.
- Configure Extensible Authentication Protocol–Transport Layer Security (EAP-TLS) with machine certificates on the VLAN 80 access ports, in monitor mode.
- Prove the pilots authenticate and that NPS logs every result.

Follow the build

1. Add the Network Policy Server role to SBD-DHCP01 and register it in Active Directory. Give it a server certificate with the Server Authentication purpose from the issuing CA. It handles port admission only; router logins stay the named local accounts from course 1.5, so the server stays in the member-server tier.
2. Add the VLAN 80 access switch as a RADIUS client with a long, unique shared secret, then create the network policy: wired 802.1X, EAP-TLS only, machine certificates that chain to the approved root and carry the Client Authentication purpose, from the Domain Computers group.
3. Create quarantine VLAN 90 with no gateway and no routes and set it as the ports' failure and guest VLAN, but enable 802.1X on the VLAN 80 access ports in monitor (audit) mode: the switch runs every authentication and reports the result, yet keeps forwarding on VLAN 80 whatever the outcome (vendors name this mode differently). The other 47 PCs have no machine certificate until they join the domain in lesson 6, so enforcing now would strand them in VLAN 90, with no route to a domain controller. Push the wired 802.1X client settings to the Workstations OU by Group Policy (Wired AutoConfig, EAP-TLS, the approved root as the trusted CA).
4. Prove monitor mode with the pilots: each authenticates with EAP-TLS and NPS logs a grant (event 6272), while a failed attempt is logged — as event 6273 when the request reaches NPS — but still forwards on VLAN 80. Add register row F20 with its owner, and confirm the NPS events reach the course 1.8 collector through the existing event forwarding subscription.

Check your result

```
# On an enrolled pilot: the wired interface authenticated with EAP-TLS.
netsh lan show interfaces
# On SBD-DHCP01: recent NPS grants (6272) and denials (6273).
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=6272,6273} -MaxEvents 5 | Select-
Object TimeCreated, Id
```

WHAT SUCCESS LOOKS LIKE Every pilot authenticates with EAP-TLS and NPS logs the grant (6272); a failed authentication is logged but, in monitor mode, the port still forwards on VLAN 80; the ports name VLAN 90 as their failure VLAN; and the NPS events appear in the collector.

Your record

Evidence to keep: Keep the network policy export, the RADIUS client list (without the secret), the monitor-mode port configuration, the pilots' grant events and the failed test, and the F20 register row.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Once 802.1X is enforced, what lets a workstation onto a VLAN 80 port?

> **REMEMBER** 802.1X runs on every VLAN 80 port in monitor mode: every result is logged, nothing is blocked yet. The pilots authenticate with machine certificates; enforcement waits until the whole fleet has enrolled. No new server: NPS runs on SBD-DHCP01, and its decisions are logged with everything else.

Microsoft · Network Policy Server overview

Microsoft · Configure RADIUS clients

Microsoft · Certificate requirements for EAP-TLS

LESSON 06 / ABOUT 30 MIN

Scale to fifty, enforce 802.1X, and prove by sample

WHY THIS MATTERS Roll the remaining waves while the ports are still in monitor mode, confirm every PC enrolled its machine certificate and authenticates, then switch the ports to enforcement — and prove the fleet the only honest way at scale: a defined sample, the same checks as the pilot, and a written rule for what a sample failure means.

In this lesson you will

- Roll out the remaining endpoints in planned waves.
- Confirm fleet-wide enrollment, then enforce 802.1X and prove an unenrolled device is quarantined.
- Verify a defined sample against the pilot's full check set and widen event forwarding to the fleet.

Follow the build

1. Deploy the remaining machines in the planned waves while the VLAN 80 ports are still in monitor mode, watching the DHCP scope's utilization and the join events arriving in analysis as each wave lands — the pipeline is now the rollout's progress bar.
2. Confirm every PC enrolled its machine certificate and authenticates: compare the issuing CA's issued certificates and the NPS grant events (6272) against the fifty computer objects, and fix any machine that is missing before going further.
3. Switch the VLAN 80 access ports from monitor mode to enforcement, and prove it both ways: an enrolled PC still authenticates and gets its normal lease, and an unenrolled test laptop lands in quarantine VLAN 90 and reaches nothing. Record the switch's port status and the NPS events for both.
4. Define the sample before checking it: for example one machine per wave plus any machine that logged an error — then run the pilot's full set on each sampled host (OU, policy, DNS, LAPS, certificate, 802.1X admission, peer-deny).
5. Write the sample rule down: one failed check in the sample widens the sample; a repeated failure stops the rollout and becomes a finding. A sample without a failure rule is a formality.
6. Extend the course 1.8 forwarding subscription to the Workstations OU so all fifty endpoints report their security events — and confirm fleet sign-ins now appear in the analyst's searches.

Check your result

```
(Get-ADComputer -SearchBase 'OU=Workstations,OU=SBD,DC=sbd,DC=test' -Filter *).Count
# On SBD-DHCP01: authentication results in the last hour (6272 granted, 6273 denied).
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=6272,6273; StartTime=(Get-
Date).AddHours(-1)} | Group-Object Id | Select-Object Name, Count
Get-DhcpServerv4ScopeStatistics -ScopeId 10.0.80.0 | Select-Object PercentageInUse,
AddressesInUse
Get-WinEvent -LogName ForwardedEvents -MaxEvents 5 | Select-Object MachineName, Id
```

WHAT SUCCESS LOOKS LIKE Fifty computer objects sit in the Workstations OU, every PC enrolled and authenticates, the ports enforce 802.1X with the unenrolled laptop quarantined in VLAN 90, scope utilization matches the rollout, every sampled host passes the full check set, and fleet events flow through the pipeline.

© 2026 Secure By Design Team LLC.

Your record

Evidence to keep: Keep the wave log, the enrollment reconciliation, the enforcement change with both admission results and their records, the sample definition with its failure rule, the per-sample check results, and the widened subscription proof.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why prove the fleet by sample instead of checking all fifty by hand?

REMEMBER Fifty machines, rolled in waves, watched as they landed. Every PC enrolled before enforcement; an unenrolled device now lands in VLAN 90. A defined sample with a failure rule carried the proof, and the fleet reports into the pipeline.

Microsoft · Configure certificate autoenrollment

Microsoft · Use Windows Event Forwarding to help with intrusion detection

NIST · SP 800-53 Rev. 5 security controls

Microsoft · Network Policy Server overview

LESSON 07 / ABOUT 20 MIN

Delta scan the fleet and hand off

> **WHY THIS MATTERS** The cadence meets its first population: Security Content Automation Protocol (SCAP) baselines on the sampled endpoints with the Windows 11 benchmark, rescans where the course changed infrastructure, and a fleet inventory that course 1.10's tooling will take over.

In this lesson you will

- Baseline sampled endpoints with the Windows 11 STIG benchmark.
- Rescan the infrastructure this course touched.
- Hand the fleet inventory to course 1.10's management tooling.

Follow the build

1. Run the SCAP Compliance Checker (SCC) with the Windows 11 STIG benchmark against the sampled endpoints — the same sample set as lesson 6 — and note how much the pre-linked policies and the OS defaults already satisfy, exactly as the server baselines taught.
2. Rescan what changed: the DCs (schema and LAPS attributes), the issuing CA (fleet enrollment volume), and SBD-DHCP01 (the new NPS role and a scope in daily use); attribute each delta to its lesson.
3. Assemble the fleet inventory — names, image ancestry, certificate thumbprints, sample status — as the course's closing artifact; course 1.10's management tooling will take ownership of keeping it current.
4. Write the handoff: the fleet exists, watched and hardened, but updates itself not at all — patching, endpoint protection, and vulnerability coverage are precisely what course 1.10 builds next.

Check your result

```
Get-ChildItem C:\Evidence\workstation-fleet -Recurse | Select-Object Name, LastWriteTime
Get-FileHash -Algorithm SHA256 C:\Evidence\workstation-fleet\*
```

> **WHAT SUCCESS LOOKS LIKE** Sampled endpoints hold dated Windows 11 baselines, the infrastructure rescans carry attributed deltas, and the fleet inventory is complete and filed.

Your record

Evidence to keep: Finish the checklist: endpoint baselines, infrastructure rescans, the fleet inventory, and the handoff note to course 1.10.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	

RECORD	YOUR OBSERVATION
Open items or findings	

Think it through

Which benchmark do the endpoints get?

> **REMEMBER** Endpoint baselines by sample; infrastructure deltas attributed. The fleet inventory is the closing artifact. The gap — patching and protection — is named for course 1.10.

DISA · STIG Group Policy Objects package

NIST · SP 800-53 Rev. 5 security controls

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Prepare the fleet rollout	☐ yes	
02 Join the pilot and inspect first boot	☐ yes	
03 Manage local administrators with Windows LAPS	☐ yes	
04 Autoenroll the fleet's certificates	☐ yes	
05 Admit only enrolled devices with 802.1X	☐ yes	
06 Scale to fifty, enforce 802.1X, and prove by sample	☐ yes	
07 Delta scan the fleet and hand off	☐ yes	

Open items carried forward

Next in the learning path

That completes course 1.9. Course 1.10 keeps the fleet alive: updates, approved software, endpoint protection, and the scanner that watches for weakness.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.